

UNIVERSIDADE DE MOGI DAS CRUZES

BACHARELADO EM ENGENHARIA DE
SOFTWARE

Higor de Castro Venancio da Silva

João Vitor Rodrigues

Documentação técnica StudyFlow

Mogi das Cruzes

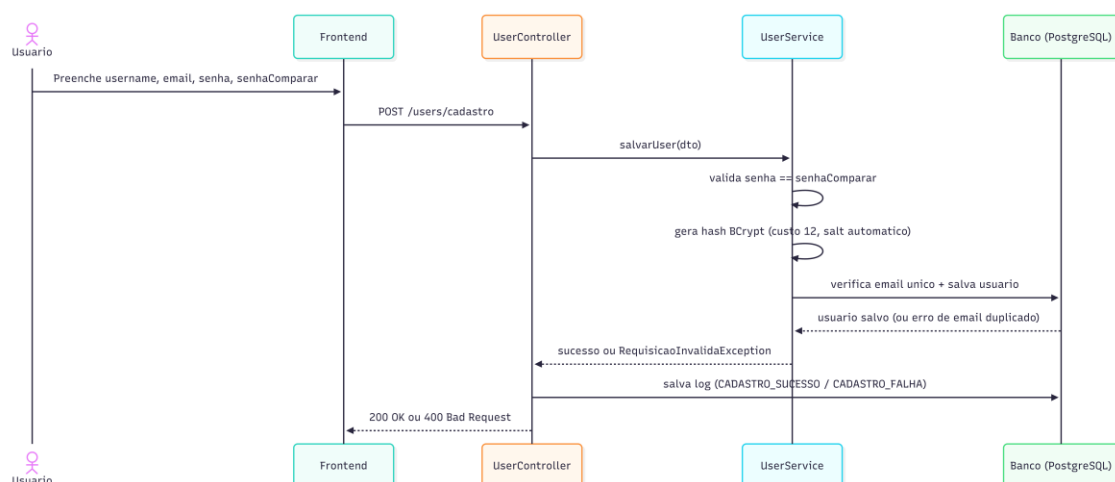
2026

Fluxo de Autenticação

O sistema de autenticação do StudyFlow é composto por cinco etapas principais: **cadastro**, **login (email e senha)**, **validação de dois fatores (2FA)**, **manutenção de sessão** e **logout**.

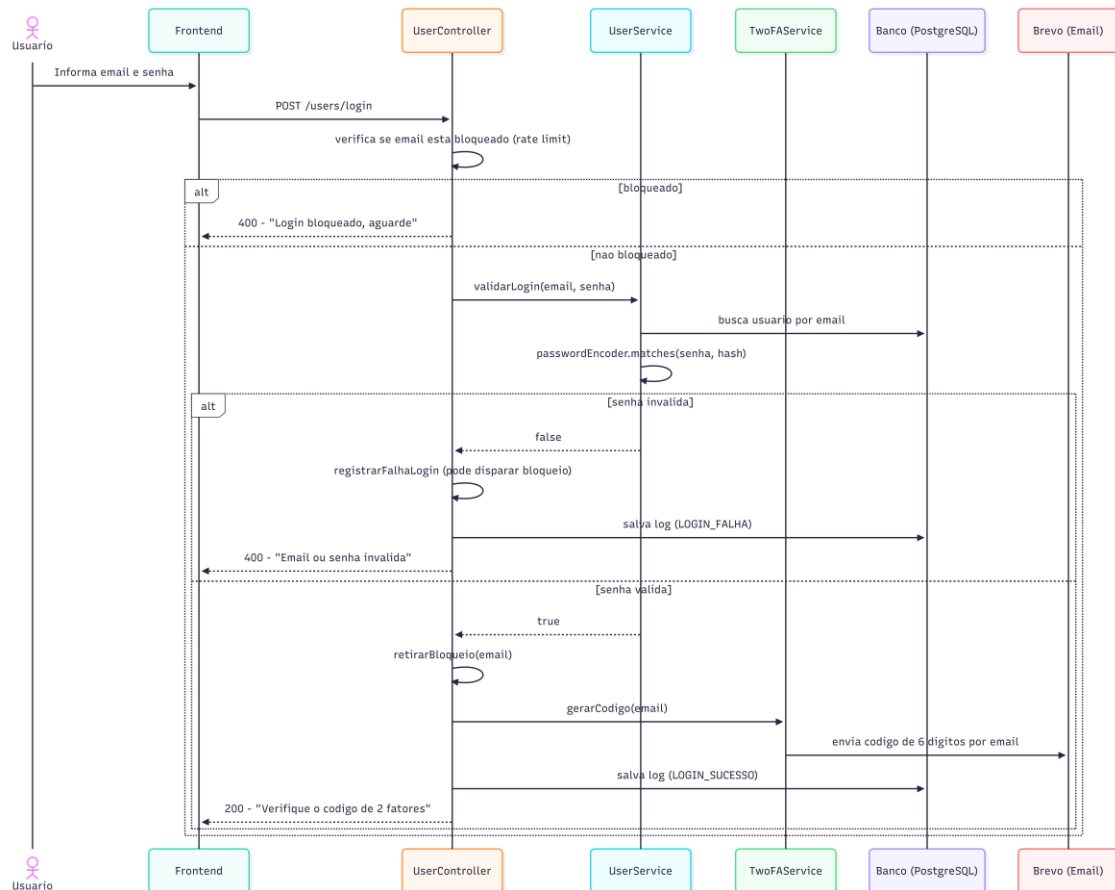
Cadastro

O usuário informa username, email, senha e senhaComparar. O backend valida se as senhas coincidem, verifica se o email já está cadastrado (restrição UNIQUE na tabela users) e, em caso positivo, gera o hash da senha com BCrypt antes de persistir o registro.



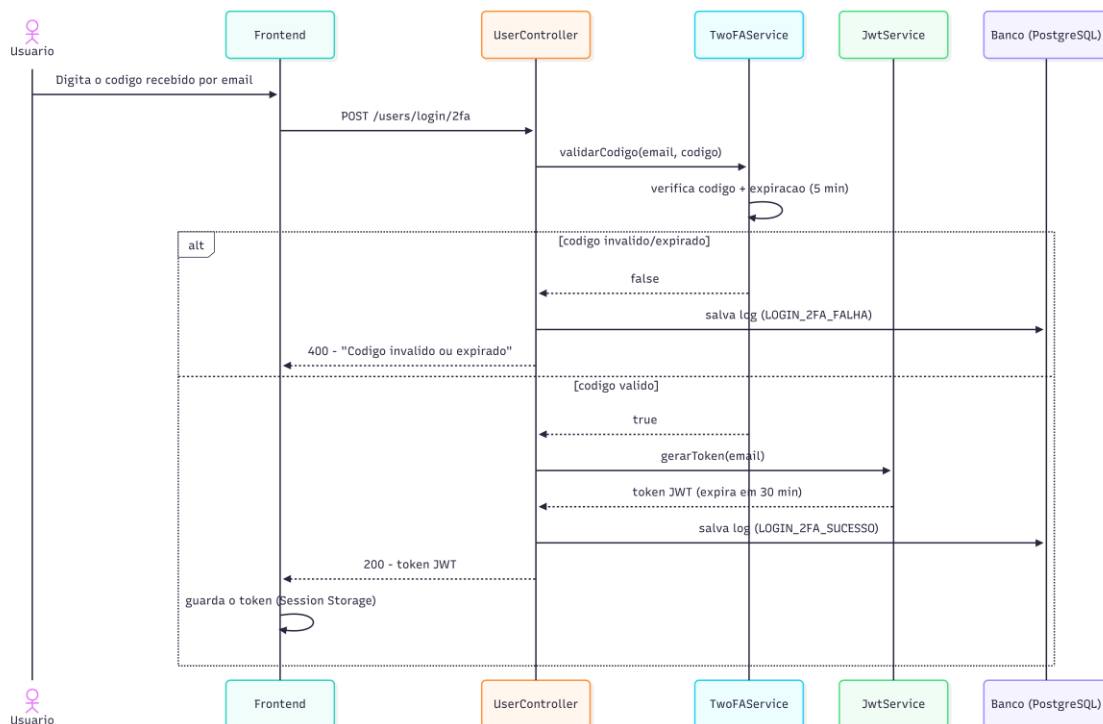
Login — Etapa 1 (email e senha)

O usuário informa email e senha. O sistema primeiro verifica se o email está temporariamente bloqueado (proteção contra força bruta). Caso não esteja, compara a senha informada com o hash armazenado. Se a senha for inválida, o sistema registra a tentativa (podendo disparar um bloqueio temporário) e retorna erro. Se for válida, o sistema gera um código de verificação de 6 dígitos e envia por email, aguardando a segunda etapa.



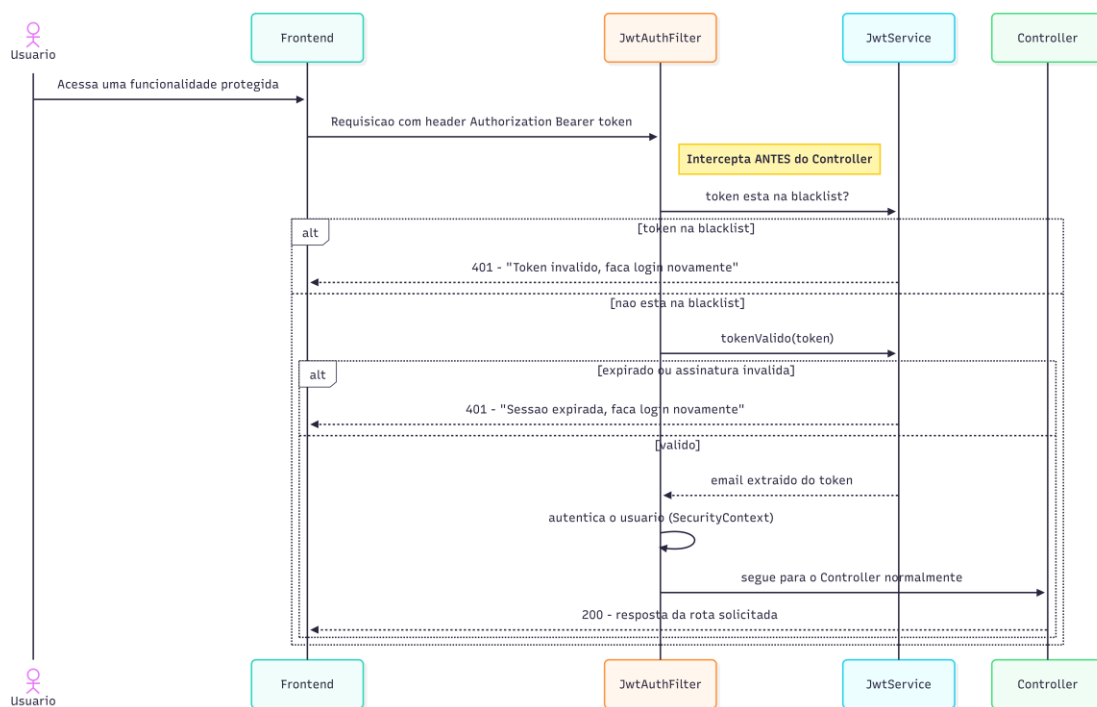
Login — Etapa 2 (2FA)

O usuário informa o código recebido por email. O sistema valida o código e sua janela de expiração (5 minutos). Sendo válido, é gerado um token JWT (válido por 30 minutos).



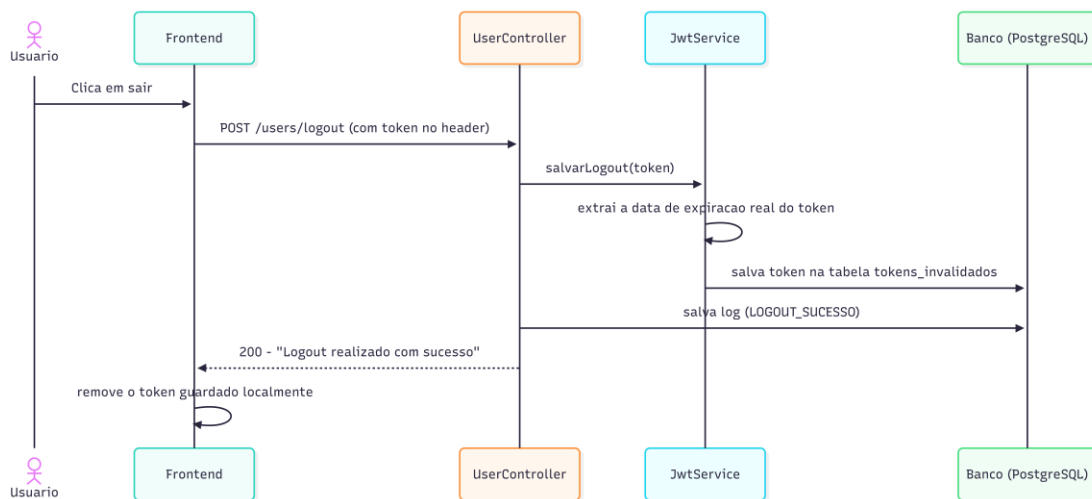
Sessão

Toda requisição a uma rota protegida passa pelo **JwtAuthFilter**, que verifica se o token está na lista de tokens invalidados e se ainda é válido (assinatura e expiração). Somente então a requisição é encaminhada ao **Controller** correspondente.



Logout

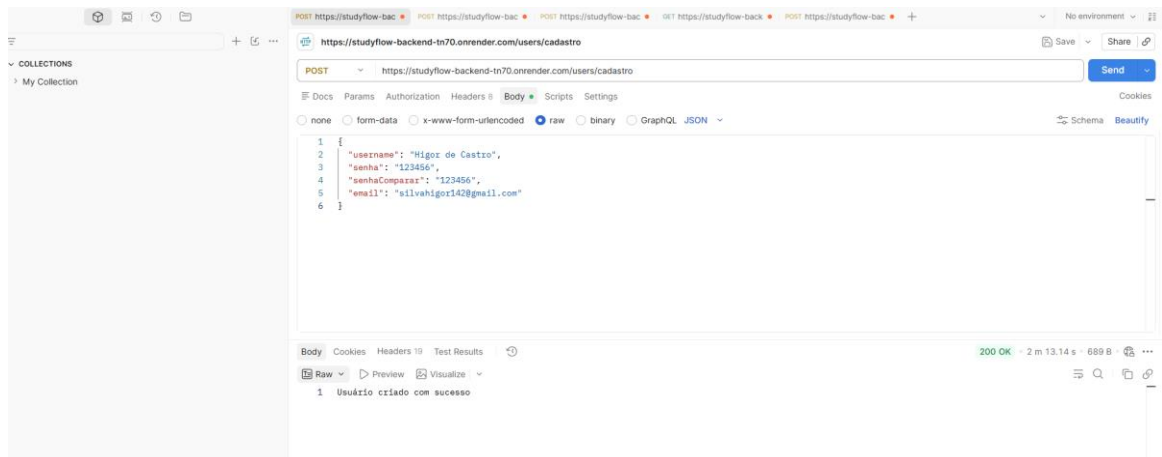
O usuário envia o token atual para o endpoint de logout. O token é registrado na tabela `tokens_invalidados`, junto de sua data de expiração original, impedindo seu reuso mesmo que ainda não tenha expirado naturalmente.



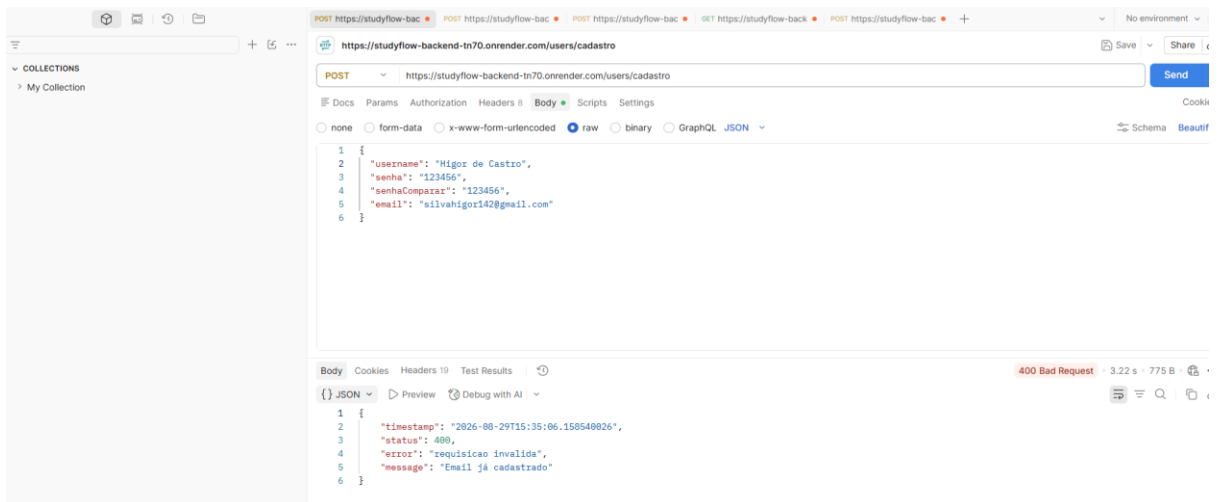
Evidências Funcionais

Prints do Postman

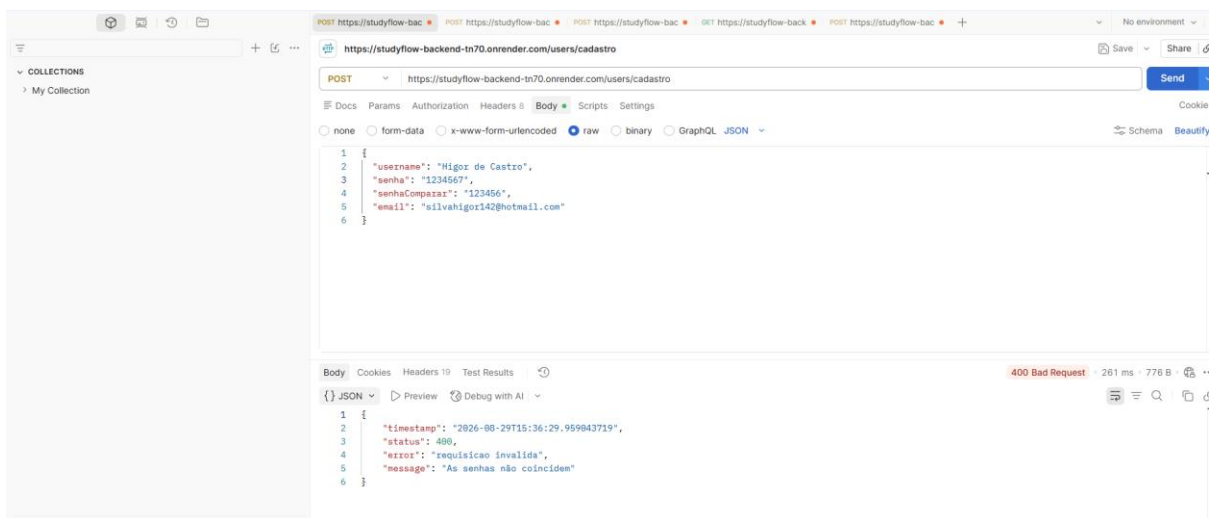
- Cadastro com sucesso:



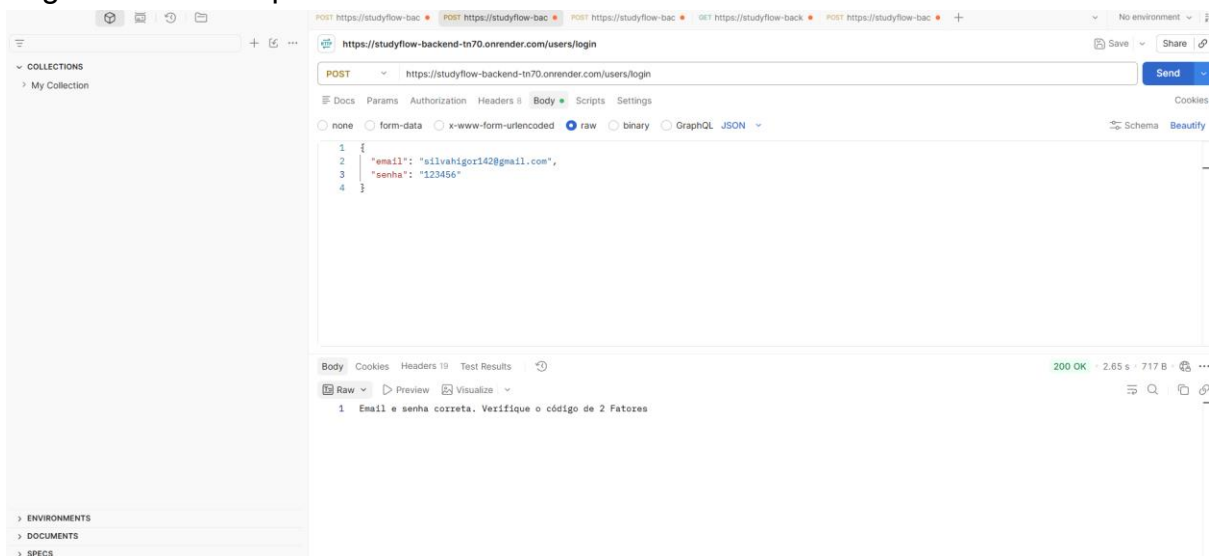
- Cadastro com email duplicado erro:



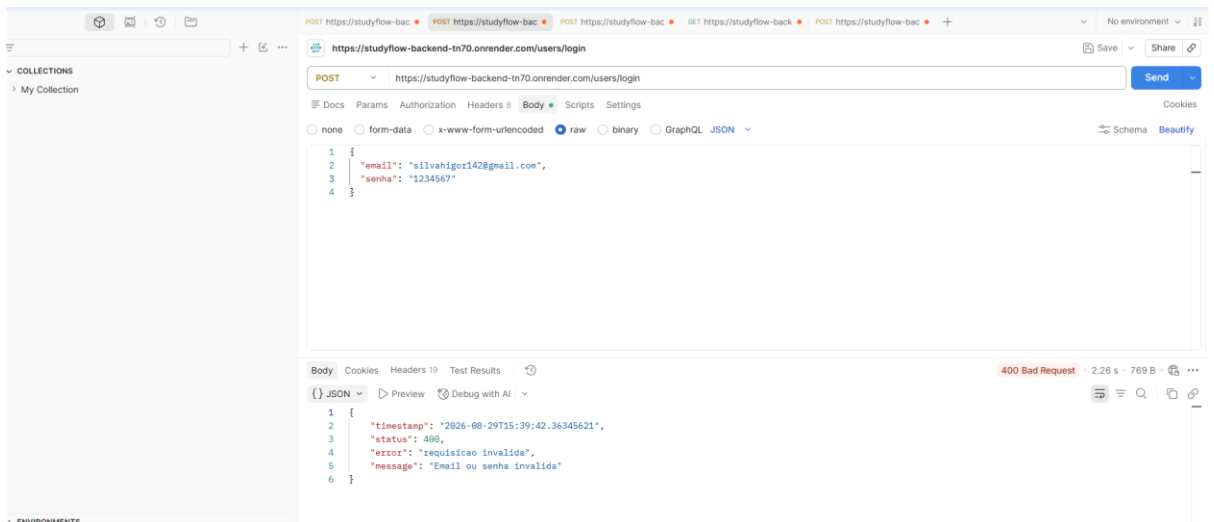
- Cadastro com senhas diferentes erro:



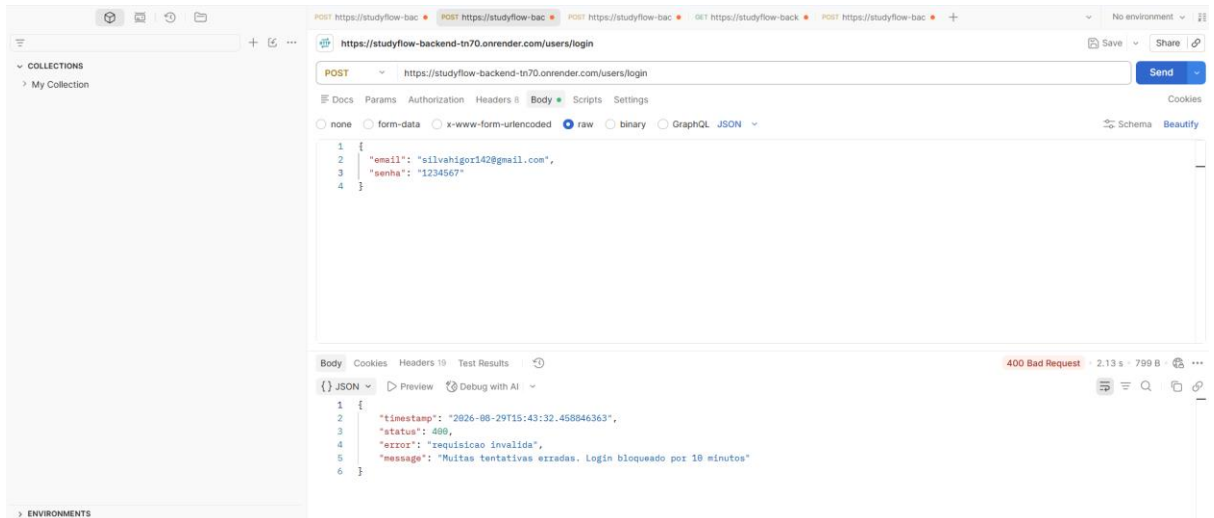
- Login válido — etapa 1:



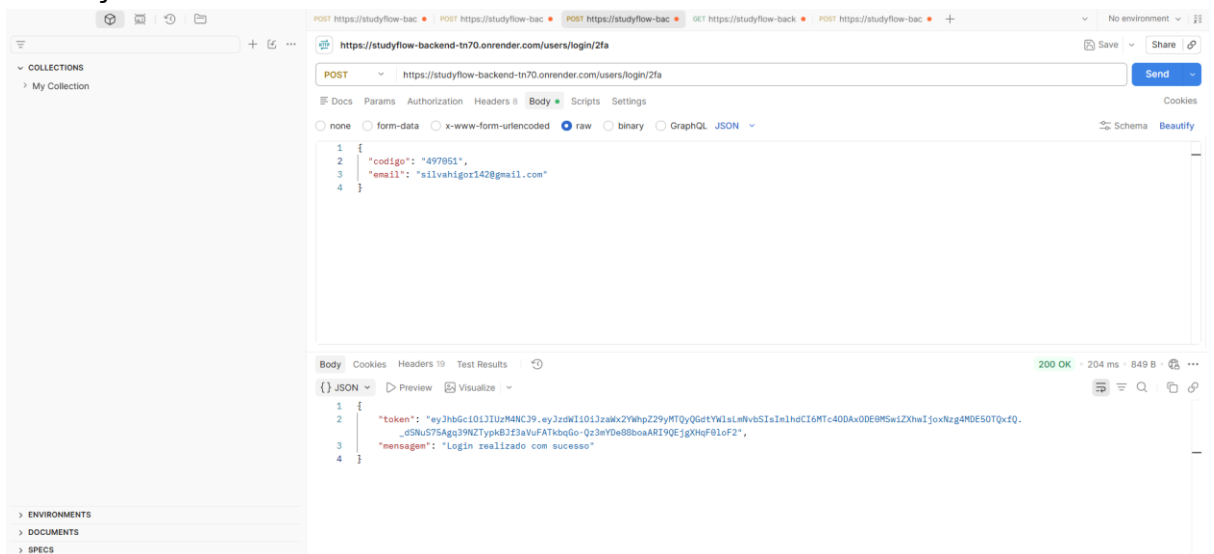
- Login com senha incorreta erro:



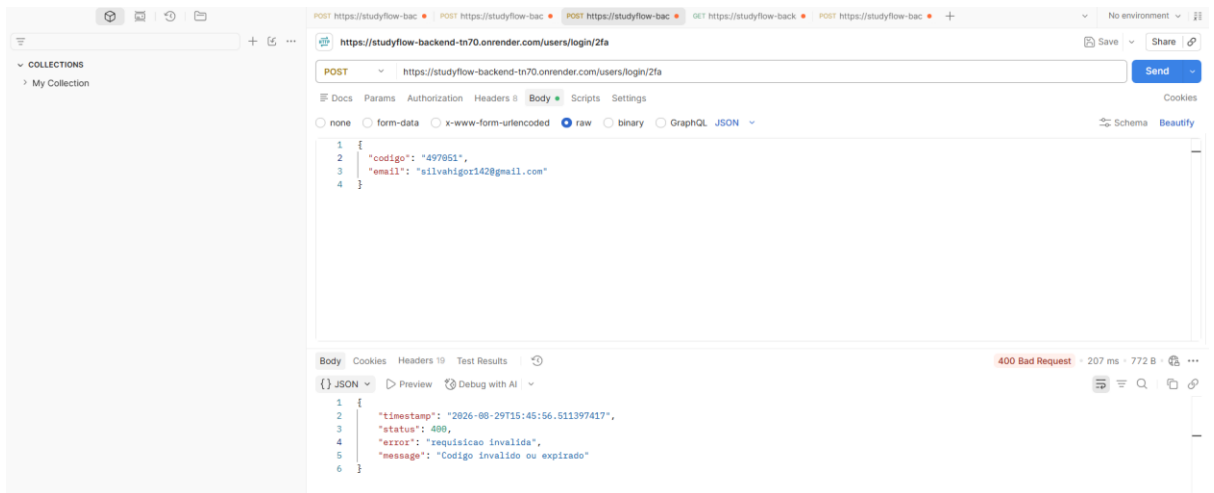
- Login bloqueado após tentativas excessivas:



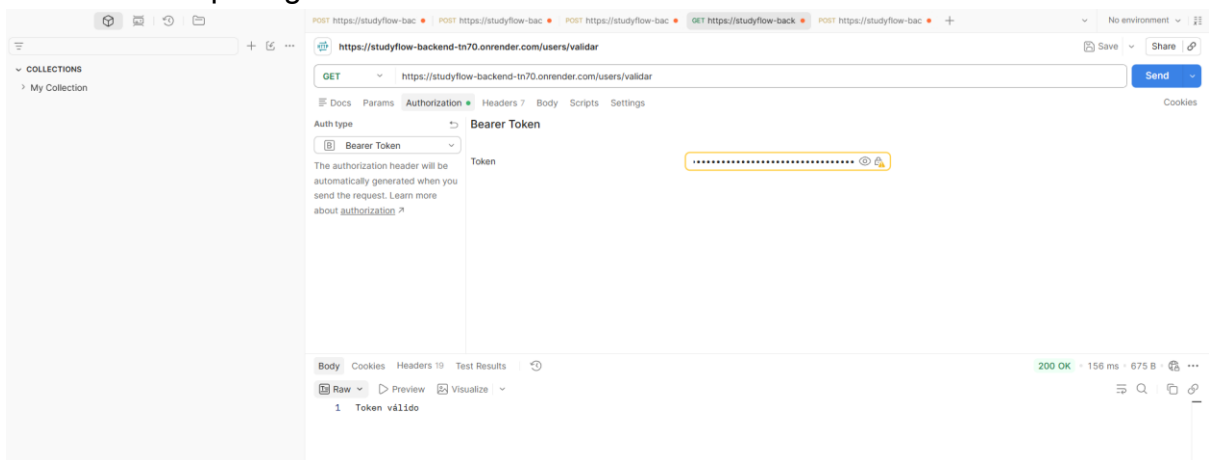
- Validação de 2FA com sucesso:



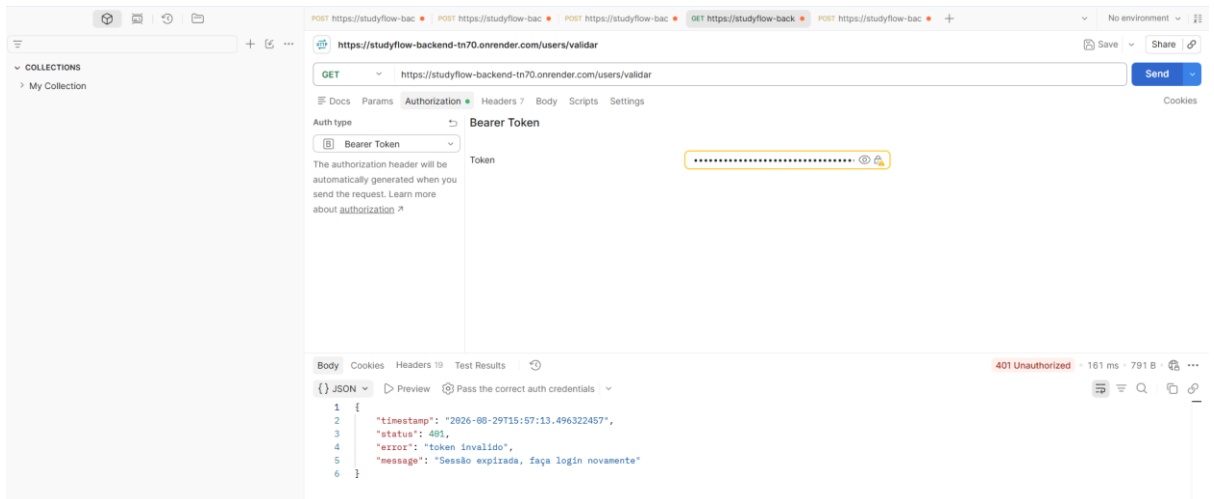
- Validação de 2FA com código incorreto/expirado:



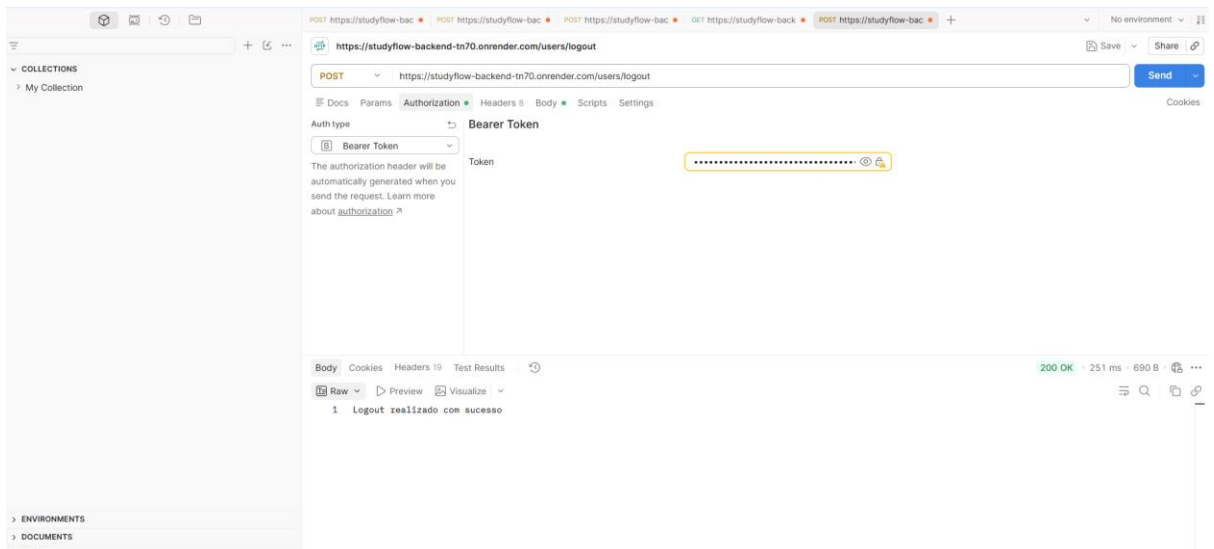
- Acesso a rota protegida com token válido:



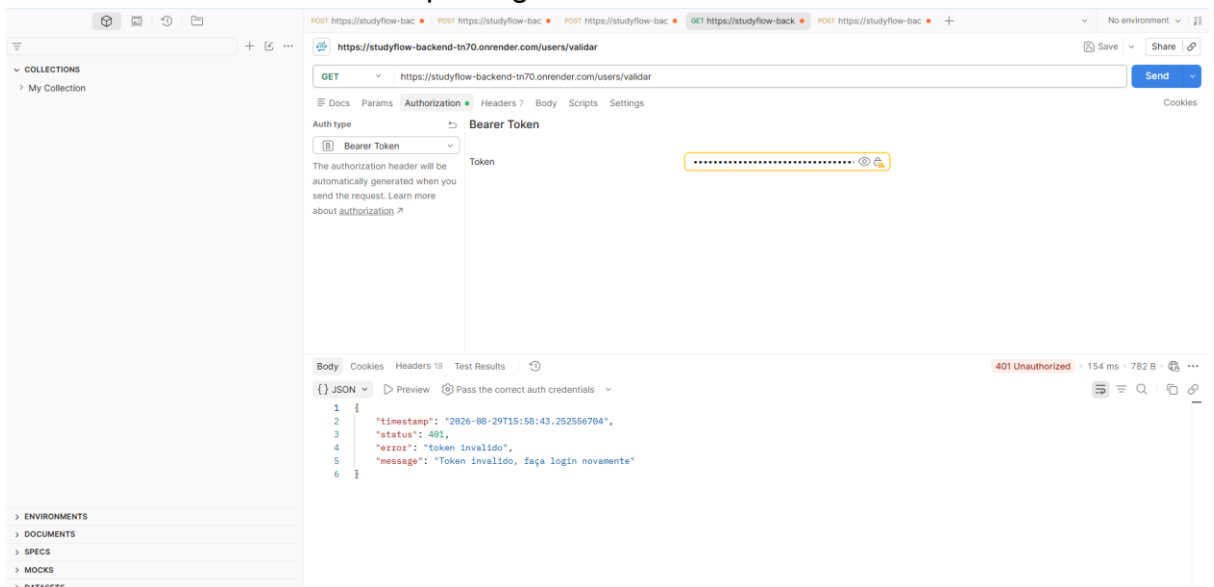
- Acesso a rota protegida com token inválido/expirado:



- Logout:



- Tentativa de reutilizar token após logout:



Prints do banco de dados

- Tabela logs mostrando eventos de CADASTRO_SUCESSO / CADASTRO_FALHA:

```
studyflow_nbrz=> SELECT * FROM logs
studyflow_nbrz=> WHERE tipo IN ('CADASTRO_SUCESSO', 'CADASTRO_FALHA')
studyflow_nbrz=> ORDER BY data_hora DESC;
```

id	tipo	email	mensagem	data_hora
163	CADASTRO_FALHA	silvahigor142@hotmail.com	CADASTRO FALHA: As senhas não coincidem	2026-08-29 15:36:29.873039
162	CADASTRO_FALHA	silvahigor142@gmail.com	CADASTRO FALHA: Email j8 cadastrado	2026-08-29 15:35:06.058892
161	CADASTRO_SUCESSO	silvahigor142@gmail.com	Usu8rio criado com sucesso	2026-08-29 15:33:51.96484
147	CADASTRO_FALHA	joaovr724@gmail.com	CADASTRO FALHA: Email j8 cadastrado	2026-08-29 13:30:38.204634
121	CADASTRO_SUCESSO	renan@gmail.com	Usu8rio criado com sucesso	2026-08-28 22:13:08.387109
117	CADASTRO_SUCESSO	jones@gmail.com	Usu8rio criado com sucesso	2026-08-28 18:27:46.471748

-- Mais --

- Tabela logs mostrando eventos de LOGIN_SUCESSO / LOGIN_FALHA:

```
studyflow_nbrz=> SELECT * FROM logs
studyflow_nbrz-> WHERE tipo IN ('LOGIN_SUCESSO', 'LOGIN_FALHA')
studyflow_nbrz-> ORDER BY data_hora DESC;
```

id	tipo	email	mensagem	data_hora
177	LOGIN_SUCESSO	silvahigor142@gmail.com	Email e senha correta 2FA enviado	2026-08-29 15:55:39.950839
173	LOGIN_FALHA	silvahigor142@gmail.com	Email ou senha invalida	2026-08-29 15:43:28.47193
172	LOGIN_FALHA	silvahigor142@gmail.com	Email ou senha invalida	2026-08-29 15:43:25.667079
171	LOGIN_FALHA	silvahigor142@gmail.com	Email ou senha invalida	2026-08-29 15:43:22.872433
170	LOGIN_FALHA	silvahigor142@gmail.com	Email ou senha invalida	2026-08-29 15:43:19.758353
167	LOGIN_SUCESSO	silvahigor142@gmail.com	Email e senha correta 2FA enviado	2026-08-29 15:40:38.158987
165	LOGIN_FALHA	silvahigor142@gmail.com	Email ou senha invalida	2026-08-29 15:39:42.357784
164	LOGIN_SUCESSO	joaovr724@gmail.com	Email e senha correta 2FA enviado	2026-08-29 15:39:03.559209
159	LOGIN_SUCESSO	joaovr724@gmail.com	Email e senha correta 2FA enviado	2026-08-29 14:46:07.250389
156	LOGIN_SUCESSO	joaovr724@gmail.com	Email e senha correta 2FA enviado	2026-08-29 14:43:21.951621
153	LOGIN_SUCESSO	joaovr724@gmail.com	Email e senha correta 2FA enviado	2026-08-29 14:40:59.375987
150	LOGIN_SUCESSO	joaovr724@gmail.com	Email e senha correta 2FA enviado	2026-08-29 14:37:38.75592
149	LOGIN_FALHA	joaovr724@gmail.com	Email ou senha invalida	2026-08-29 14:37:27.858271
145	LOGIN_FALHA	higorcastro142@gmail.com	Email ou senha invalida	2026-08-29 13:29:23.206255
144	LOGIN_FALHA	higorcastro142@gmail.com	Email ou senha invalida	2026-08-29 13:29:19.205749
143	LOGIN_FALHA	higorcastro142@gmail.com	Email ou senha invalida	2026-08-29 13:29:14.805916
142	LOGIN_FALHA	higorcastro142@gmail.com	Email ou senha invalida	2026-08-29 13:29:10.505547
138	LOGIN_SUCESSO	joaovr724@gmail.com	Email e senha correta 2FA enviado	2026-08-29 13:25:13.995272
137	LOGIN_SUCESSO	higorcastro142@gmail.com	Email e senha correta 2FA enviado	2026-08-29 13:25:11.696645
135	LOGIN_SUCESSO	joaovr724@gmail.com	Email e senha correta 2FA enviado	2026-08-29 13:04:42.555576
133	LOGIN_SUCESSO	joaovr724@gmail.com	Email e senha correta 2FA enviado	2026-08-29 12:56:41.958242
130	LOGIN_SUCESSO	joaovr724@gmail.com	Email e senha correta 2FA enviado	2026-08-29 12:54:07.842245
128	LOGIN_SUCESSO	joaovr724@gmail.com	Email e senha correta 2FA enviado	2026-08-29 12:39:20.278777

- Tabela logs mostrando eventos de LOGIN_2FA_SUCESSO / LOGIN_2FA_FALHA:

```
studyflow_nbrz=> SELECT * FROM logs
studyflow_nbrz-> WHERE tipo IN ('LOGIN_2FA_SUCESSO', 'LOGIN_2FA_FALHA')
studyflow_nbrz-> ORDER BY data_hora DESC;
```

id	tipo	email	mensagem	data_hora
178	LOGIN_2FA_SUCESSO	silvahigor142@gmail.com	2FA Correto	2026-08-29 15:56:21.033202
175	LOGIN_2FA_FALHA	silvahigor142@gmail.com	Codigo invalido ou expirado	2026-08-29 15:45:56.505188
168	LOGIN_2FA_SUCESSO	silvahigor142@gmail.com	2FA Correto	2026-08-29 15:42:21.06943
166	LOGIN_2FA_SUCESSO	joaovr724@gmail.com	2FA Correto	2026-08-29 15:39:42.760337
160	LOGIN_2FA_SUCESSO	joaovr724@gmail.com	2FA Correto	2026-08-29 14:46:36.410611
157	LOGIN_2FA_SUCESSO	joaovr724@gmail.com	2FA Correto	2026-08-29 14:43:31.305053
154	LOGIN_2FA_SUCESSO	joaovr724@gmail.com	2FA Correto	2026-08-29 14:41:15.310256
151	LOGIN_2FA_SUCESSO	joaovr724@gmail.com	2FA Correto	2026-08-29 14:37:56.0556
140	LOGIN_2FA_SUCESSO	joaovr724@gmail.com	2FA Correto	2026-08-29 13:25:58.671058
139	LOGIN_2FA_SUCESSO	higorcastro142@gmail.com	2FA Correto	2026-08-29 13:25:53.998825
136	LOGIN_2FA_SUCESSO	joaovr724@gmail.com	2FA Correto	2026-08-29 13:04:58.29876
134	LOGIN_2FA_SUCESSO	joaovr724@gmail.com	2FA Correto	2026-08-29 12:56:51.368593
131	LOGIN_2FA_SUCESSO	joaovr724@gmail.com	2FA Correto	2026-08-29 12:54:20.960757
129	LOGIN_2FA_SUCESSO	joaovr724@gmail.com	2FA Correto	2026-08-29 12:40:00.544418
127	LOGIN_2FA_SUCESSO	higorcastro142@gmail.com	2FA Correto	2026-08-29 10:51:19.50129
125	LOGIN_2FA_SUCESSO	joaovr724@gmail.com	2FA Correto	2026-08-28 22:17:51.432812
123	LOGIN_2FA_SUCESSO	joaovr724@gmail.com	2FA Correto	2026-08-28 22:13:40.142519
120	LOGIN_2FA_SUCESSO	joaovr724@gmail.com	2FA Correto	2026-08-28 22:03:59.678481
116	LOGIN_2FA_FALHA	joaovr724@gmail.com	Codigo invalido ou expirado	2026-08-28 18:27:10.926924
115	LOGIN_2FA_FALHA	joaovr724@gmail.com	Codigo invalido ou expirado	2026-08-28 18:26:48.024602
113	LOGIN_2FA_FALHA	joaovr724@gmail.com	Codigo invalido ou expirado	2026-08-28 18:21:51.767966
109	LOGIN_2FA_SUCESSO	joaovr724@gmail.com	2FA Correto	2026-08-28 18:12:00.556179
108	LOGIN_2FA_FALHA	joaovr724@gmail.com	Codigo invalido ou expirado	2026-08-28 18:10:42.789004
107	LOGIN_2FA_FALHA	joaovr724@gmail.com	Codigo invalido ou expirado	2026-08-28 18:08:59.872873
104	LOGIN_2FA_SUCESSO	joaovr724@gmail.com	2FA Correto	2026-08-28 15:06:52.04373
101	LOGIN_2FA_SUCESSO	joaovr724@gmail.com	2FA Correto	2026-08-28 14:02:22.952731

- Tabela logs mostrando eventos de LOGIN_BLOQUEADO_FALHA:

```
studyflow_nbrz=> SELECT * FROM logs
studyflow_nbrz-> WHERE tipo = 'LOGIN_BLOQUEADO_FALHA'
studyflow_nbrz-> ORDER BY data_hora DESC;
```

id	tipo	email	mensagem	data_hora
174	LOGIN_BLOQUEADO_FALHA	silvahigor142@gmail.com	Bloqueado por 10 minutos apos 5 tentativas erradas	2026-08-29 15:43:32.368146
146	LOGIN_BLOQUEADO_FALHA	higorcastro142@gmail.com	Bloqueado por 10 minutos apos 5 tentativas erradas	2026-08-29 13:29:27.206478
39	LOGIN_BLOQUEADO_FALHA	joaovr724@gmail.com	Bloqueado por 10 minutos apos 5 tentativas erradas	2026-08-27 13:07:08.653546

(3 linhas)

- Tabela logs mostrando eventos de LOGOUT_SUCESSO:

- Tabela users mostrando o campo senha no formato \$2a\$12\$... (hash + salt):

- Tabela tokens_invalidados mostrando um token após logout:

Prints da front-end

- Se o cadastro for um sucesso, vai ser direcionado para tela de 2FA

- Erro caso erre a senha ou e-mail

Login

E-mail:

Senha:

Entrar

Email ou senha Invalida

Cliente não cadastrado? [Clique aqui](#)

- Login bloqueado após tentativas excessivas

Login

E-mail:

Senha:

Entrar

Muitas tentativas erradas. Login bloqueado por 10 minutos

Cliente não cadastrado? [Clique aqui](#)

- Tela de cadastro

Cadastro

Nome:

E-mail:

Senha:

Confirmar Senha:

Cadastrar

Já tem uma conta? [Faça login](#)

Se o cadastro for um sucesso é direcionado para tela de login

- Erro caso e-mail já tenha sido cadastrado

Cadastro

Nome:

E-mail:

Senha:

Confirmar Senha:

Email já cadastrado

Já tem uma conta? [Faça login](#)

- Erro caso as senhas informadas sejam diferentes

Cadastro

Nome:

E-mail:

Senha:

Confirmar Senha:

As senhas não são iguais

Já tem uma conta? [Faça login](#)

- Erro no caso do e-mail ser invalido

Cadastro

Nome:

E-mail:

 Inclua um "@" no endereço de e-mail. "joaovr" está com um "@" faltando.

.....

Confirmar Senha:

As senhas não são iguais

Já tem uma conta? [Faça login](#)

- Tela de 2FA

Verificação de duas Etapas

Digite o código de 6 dígitos enviado para e-mail cadastrado. **Pode chegar como Spam.**

Caso o código esteja correto, será direcionado para tela Home

- Erro caso tenha menos de 6 dígitos

Verificação de duas Etapas

Digite o código de 6 dígitos enviado para e-mail cadastrado. **Pode chegar como Spam.**

[Voltar](#) [Confirmar código](#)

O código precisa ter exatamente 6 dígitos

- Erro caso o token estiver expirado ou invalido

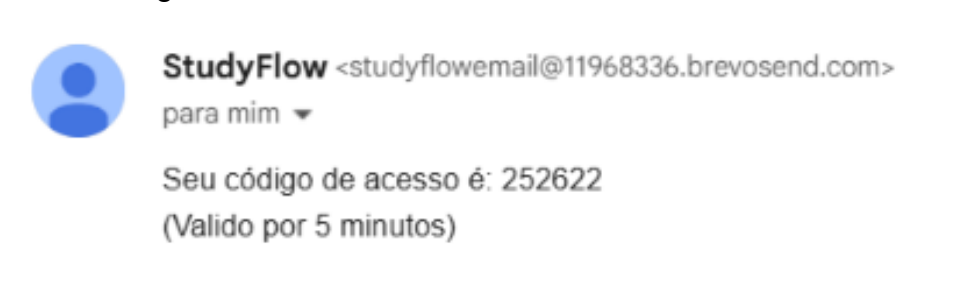
Verificação de duas Etapas

Digite o código de 6 dígitos enviado para e-mail cadastrado. **Pode chegar como Spam.**

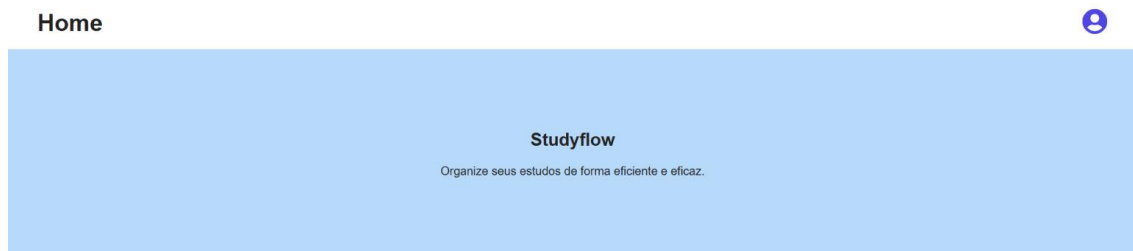
[Voltar](#) [Confirmar código](#)

Código inválido ou expirado

- Token chegando o e-mail



- Tela Home



Quando clicar no ícone superior direito será direcionado para tela de profile

- Tela profile



Por enquanto única funcionalidade é fazer o Logout e voltar para home, após clicar no botão sair vai para tela de login

- Tela após clicar em Sair

Login

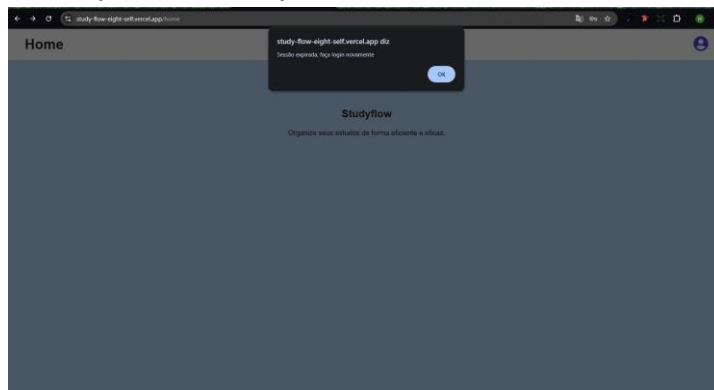
E-mail:

Senha:

Entrar

Cliente não cadastrado? [Clique aqui](#)

- Tela após token expirar



Justificativas Técnicas

Por que BCrypt?

O BCrypt foi escolhido por ser um algoritmo amplamente adotado, com suporte nativo no Spring Security (BCryptPasswordEncoder), o que reduziu a complexidade de implementação sem comprometer a segurança. Diferente do PBKDF2, o BCrypt já incorpora um salt gerado automaticamente a cada hash, eliminando a necessidade de gerenciar essa geração manualmente.

Por que o custo do hash foi definido como 12?

O parâmetro de custo do BCrypt é um expoente de base 2 ($2^{12} = 4.096$ iterações). O valor 12 foi escolhido por representar um equilíbrio entre segurança e desempenho: gera um tempo de processamento de aproximadamente 200–300ms

por hash, tornando ataques de força bruta computacionalmente custosos, sem impactar de forma perceptível a experiência do usuário durante cadastro e login.

Por que 2FA via email ?

A autenticação de dois fatores via código enviado por email foi escolhida por não depender de aplicativos externos (como Google Authenticator), reduzindo a barreira de uso para o usuário final. Embora o TOTP ofereça maior resistência a interceptação, por não depender de um canal de comunicação externo, o 2FA por email atende ao requisito de um segundo fator de autenticação, associado a algo que o usuário possui (acesso à caixa de email).

Por que JWT com 30 minutos de expiração?

O tempo de 30 minutos foi definido como um equilíbrio entre segurança e usabilidade. Tokens invalidados manualmente (logout) são armazenados em uma tabela de blacklist até sua expiração natural, garantindo que a invalidação seja efetiva mesmo antes do prazo de 30 minutos se esgotar.

Por que 5 tentativas / 10 minutos de bloqueio no rate limit?

O limite de 5 tentativas incorretas antes do bloqueio segue uma prática comum em sistemas de autenticação, equilibrando a proteção contra ataques de força bruta com a tolerância a erros legítimos de digitação. O tempo de bloqueio de 10 minutos foi definido para tornar ataques automatizados computacionalmente inviáveis em escala, sem impor uma penalidade excessivamente longa a um usuário legítimo que eventualmente erre a própria senha.

Por que utilizar React Router DOM?

O React Router DOM foi escolhido para controlar a navegação entre as diferentes telas da aplicação sem a necessidade de recarregar toda a página a cada mudança de rota. Além disso, a biblioteca permite implementar rotas protegidas, sendo utilizada no projeto para impedir que usuários não autenticados acessem páginas internas, como Home e Perfil.

Por que utilizar Axios?

O Axios foi escolhido para facilitar a comunicação entre o Front-End e o Back-End por meio de requisições HTTP. A biblioteca permite centralizar o comportamento das requisições, facilitar o envio e recebimento de dados em JSON e trabalhar com mecanismos de autenticação, como o envio do token JWT. No projeto, essa

utilização foi organizada por meio do hook `useApi`, reduzindo a repetição de código e facilitando o tratamento de erros.

Por que utilizar Vite?

O Vite foi escolhido por proporcionar um ambiente de desenvolvimento rápido e simples para aplicações React. Seu servidor de desenvolvimento possui inicialização rápida e atualização automática das alterações realizadas no código, reduzindo o tempo necessário entre uma alteração e sua visualização no navegador. Isso facilita o desenvolvimento e os testes durante a implementação do sistema.